

FIGMA-MCP-POC · 2026

figma-mcp-poc

公開 S3 を経由しない、社内向け Figma MCP サーバー

TypeScript Strict

MCP SDK v1.0

Phase 7 完了

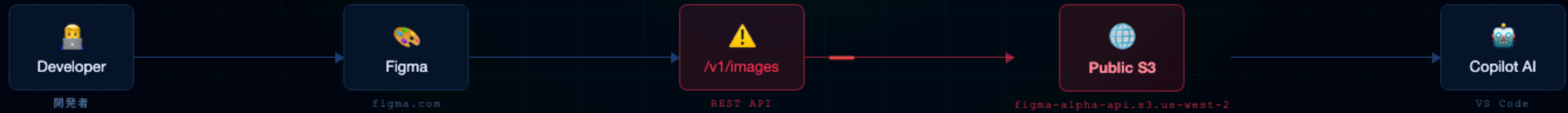
Node.js + Hono

Playwright

Supabase

Fly.io ready

公式 Figma MCP の問題点



Figma 公式 MCP は `/v1/images` を呼び出し、生成された PNG URL が `figma-alpha-api.s3.us-west-2.amazonaws.com` (公開 AWS S3) に乗る。
社外クラウドへの設計データ流出 → **データガバナンス違反**



無認証アクセス可能
presigned URL は期限内なら誰でもアクセス可



監査ログなし
誰がいつどのデザインを取得したか追跡不可



自社管理外
Figma Inc. のインフラ上にデータが滞留

提案するアプローチ

✕ 公式 MCP (従来)

- Figma REST `/v1/images` 経由で PNG URL を生成
- 画像が公開 S3 に配置される
- 署名付き URL を Copilot に渡す → 外部 URL として記録
- 監査証跡なし・データ保持期間不明

✓ figma-mcp-poc (本 PoC)

- Playwright が Figma Web を直接レンダリング
- PNG バイト → Supabase Storage (自社管理・非公開)
- MCP レスポンスは **base64 PNG インライン** (URL なし)
- 全操作を `audit_log` テーブルに記録



ガバナンス保証: `/v1/images` を一切呼び出さず、設計データは自社 Supabase プロジェクト内のみに存在。MCP ツールは公開 URL を生成しない。

システム構成



レンダリング処理フロー



技術スタック

TypeScript

strict mode + ESM。型安全な全レイヤー実装

v5.4 - NodeNext

Hono

軽量 HTTP フレームワーク。ゼロ依存・高速ルーティング

v4.6 - @hono/node-server

Playwright

Chromium headless 制御。Figma Web を永続セッションでレンダリング

v1.49 - launchPersistentContext

MCP SDK

公式 Model Context Protocol SDK。HTTP Streamable Transport

v1.0.4 - WebStandard

Supabase

Auth / PostgreSQL / Storage をワンセット。RLS によるユーザー分離

supabase-js v2

Zod

ランタイム型バリデーション。env vars・API 入力をスキーマ検証

v3.23

pnpm workspaces

モノレポ管理。shared / figma-mcp-service の 2 パッケージ構成

pnpm v9

Fly.io

コンテナデプロイ。NRT リージョン、min 1 machine (セッション保持)

Dockerfile + fly.toml 準備済み

セキュリティ設計

✓ `/v1/images` の呼び出しなし確認済み - `grep -rn "/v1/images" packages/ → 0 件`

✓ Per-user データ分離 (RLS)

全 Supabase クエリに `created_by = userId` を明示。RLS ポリシーでダブルチェック。ユーザー A が B のアセットを参照不可。

✓ 公開 URL ゼロ

MCP ツールは PNG バイトを base64 インラインで返す。presigned URL の発行ルートは MCP 経路に存在しない。

✓ 全操作の監査ログ

`audit_log` テーブルに actor / event / asset_id / meta を記録。誰がいつ何をレンダリングしたか追跡可能。

✓ 2 種類の認証方式

短寿命 `JWT` (Supabase 発行・1h) と長寿命 `fmps_` API キー (SHA256 ハッシュ保存) の両対応。

✓ Rate Limiting

IP ごとに認証失敗 60 回/分の上限。スライディングウィンドウでブルートフォース攻撃を防御。

✓ 分類タグ

アセットに `classification` (internal / confidential) と `tier` (A/B/C) を付与。将来的なアクセスポリシー差別化に対応。

現状と今後

● Phase 7 完了 – MVP 稼働中

● 実装済み

- ・ Playwright レンダリング (persistent profile)
- ・ MCP HTTP サーバー (Streamable HTTP/SSE)
- ・ 2 ツール : screenshot / node-info
- ・ JWT + fmps_ 認証
- ・ Supabase RLS per-user 分離
- ・ キャッシュ (SHA256 キー)
- ・ 監査ログ + 分類タグ
- ・ Fly.io デプロイ準備完了

● 既知の制限

- ・ セッションがインメモリ → 1 台構成のみ
- ・ キャッシュ TTL の自動削除ジョブ未実装
- ・ Figma REST 403 時は日付ベースキャッシュキーにフォールバック
- ・ テキスト可読性改善 (viewport リサイズ) 作業中
- ・ Figma ログイン失効時は手動で再ログイン必要

● 次のステップ

- ・ Redis セッションストア (水平スケール対応)
- ・ pg_cron でキャッシュ自動削除
- ・ IdP 連携 (OIDC / SAML)
- ・ WAF / DDoS 保護 (Cloudflare)
- ・ 構造化ログの外部 Sink (Datadog 等)
- ・ Fly.io デプロイ (secrets 設定後すぐ可能)